Lab 32 — Passive Reconnaissance / OSINT

You will collect public footprint of a domain you own using only **passive** tools — no packets sent to the target. This is the "unknown environment" recon phase of a pentest (Security+ 5.5).

Run on https://killercoda.com/playgrounds/scenario/ubuntu

Required software (free, apt + pip): - `whois`, `dnsutils`, `jq` - `theHarvester` (pip, from source) - `subfinder` (prebuilt binary)

Step 1 — Install

The PyPI `theHarvester` package is an abandoned stub, so install the current tool straight from source. `subfinder` now needs Go 1.24 to build, so grab the official prebuilt binary instead of using `go install`.

```
apt update && apt install -y whois dnsutils python3-pip jq unzip curl
```

```
pip3 install --break-system-packages
git+https://github.com/laramies/theHarvester.git
```

```
SF_VER=$(curl -s
https://api.github.com/repos/projectdiscovery/subfinder/releases/late
st | grep -oP '"tag_name": "v\K[^"]+')
```

```
curl -sL
"https://github.com/projectdiscovery/subfinder/releases/download/v$
{SF_VER}/subfinder_${SF_VER}_linux_amd64.zip" -o /tmp/subfinder.zip
```

```
unzip -o /tmp/subfinder.zip subfinder -d /usr/local/bin/
chmod +x /usr/local/bin/subfinder
```

Step 2 — Pick a safe target

Use a domain you own, or one explicitly authorised. For demonstrations the safe choices are `example.com` or your own organisation's domain.

```
TARGET=example.com
```

Step 3 — WHOIS (registrant + dates)

```
whois $TARGET | grep -Ei "registrar|registrant|expiry|name server" | head
```

Step 4 — DNS enumeration

```
dig +short ANY $TARGET
dig +short MX $TARGET
```

```
dig +short TXT $TARGET

dig +short NS $TARGET
```

MX, SPF, DMARC records reveal email infrastructure (and gaps).

Step 5 — Subdomain discovery (passive)

```
subfinder -silent -d $TARGET | tee subs.txt

wc -l subs.txt
```

`subfinder` queries 25+ public sources (crt.sh, VirusTotal, SecurityTrails) without touching the target.

Step 6 — Email and host harvesting

```
theHarvester -d $TARGET -b crtsh,duckduckgo,bing 2>/dev/null | tail -30
```

Step 7 — Certificate transparency

The single richest passive source:

```
curl -s "https://crt.sh/?q=%25.$TARGET&output=json" | jq -r '.
```

```
[].name_value' | sort -u | head -20
```

Every certificate ever issued for the domain is public — yes, including dev / staging hostnames teams forget to take down.

Step 8 — Public exposure check

Do **not** scan; instead use precomputed indices:

- Shodan: https://www.shodan.io/search?query=hostname%3A$TARGET
- Censys: https://search.censys.io/search?q=$TARGET
- LeakIX: https://leakix.net/search?q=$TARGET

These services already scanned the entire internet — you only consume their data.

Step 9 — Build the recon report

```
cat > recon-$TARGET.md <<EOF

# Recon Report — $TARGET

## Footprint summary

- Subdomains found: $(wc -l < subs.txt)

- DMARC: $(dig +short TXT _dmarc.$TARGET | head -1)
```

```
- SPF: $(dig +short TXT $TARGET | grep spf)




EOF



cat recon-$TARGET.md
```

Free online tools

- **crt.sh** — https://crt.sh
- **Shodan** — https://www.shodan.io
- **Censys** — https://search.censys.io
- **DNSDumpster** — https://dnsdumpster.com
- **SecurityTrails** — https://securitytrails.com
- **Whoxy WHOIS** — https://www.whoxy.com
- **Hunter.io email finder (free quota)** — https://hunter.io
- **OSINT Framework** — https://osintframework.com

What you learned

- Passive recon never touches the target — it consumes pre-collected indexes.
- Certificate transparency is the single richest source of "forgotten" subdomains.
- A 30-line recon report drives the entire pentest scoping discussion.